CASE STUDY

# The Notepad++ Update-Channel Hijack (CVE-2025-15556): A Case Study

*A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date, and sources [10] and [13] re-checked on 13 November 2026.*

## Executive summary

Notepad++ is the free text editor on a great many Windows desks, and it updates itself through a small helper program, WinGUp. For about six months in 2025, attackers who had compromised the editor's former shared hosting provider redirected the update traffic of a few chosen users and handed them a malicious installer [1] (**Confirmed** as the vendor's statement). The editor's own code was not changed [1] [2] (**Confirmed**). The weakness that made this work, an updater that did not check that what it downloaded was genuine, became CVE-2025-15556 on 3 February 2026 [10] (**Confirmed**), and CISA added it to the Known Exploited Vulnerabilities (KEV) catalog on 12 February [13] (**Confirmed**).

## Key facts at a glance

| Item | Record |
|---|---|
| CVE | CVE-2025-15556, CNA VulnCheck; CWE-494 Download of Code Without Integrity Check [10] [12] (**Confirmed**) |
| Affected | Notepad++ before 8.8.9, through its WinGUp updater [10] [12] (**Confirmed**) |
| Severity | CVSS v4.0 7.7 High (VulnCheck); NVD CVSS 3.1 7.5 [11] (**Confirmed**) |
| Compromise window | June to 2 December 2025, the vendor's estimate [1] (**Reported**) |
| Scale | About a dozen targeted machines, per Kaspersky [15] (**Reported**) |
| Payloads | Cobalt Strike, Metasploit downloaders and a backdoor Rapid7 named Chrysalis [14] [15] (**Reported**) |
| Attribution | Lotus Blossom, moderate confidence (Rapid7) [14]; no actor named by Kaspersky [15] (**Reported**) |
| KEV | Added 12 Feb 2026, due 5 Mar 2026, ransomware use Unknown [13] (**Confirmed**) |
| Fix | Signed-installer check in 8.8.9 (9 Dec 2025); verification of signed update metadata in 8.9.2 (16 Feb 2026) [4] [6] (**Confirmed**) |

## Key findings

- The attack lived in the delivery path, not the product. The hosting provider was compromised; traffic from certain targeted users was redirected to serve compromised updates [1] (**Confirmed** as vendor statement).
- The targeting was narrow. Kaspersky counts about a dozen machines across Vietnam, El Salvador, Australia and the Philippines [15] (**Reported**).
- The fix arrived in stages. The vendor flagged a hijacking issue in 8.8.8 (18 November 2025), enforced installer signatures in 8.8.9 (9 December 2025) and enforced verification of the signed update metadata only in 8.9.2 (16 February 2026) [3] [4] [6] (**Confirmed**).
- Attribution is softer than the headlines. The vendor relays a "likely" Chinese state-sponsored assessment [1] (**Reported**); Rapid7 says Lotus Blossom with moderate confidence [14] (**Reported**); ATT&CK's Lotus Blossom entry carries no China attribution and no Notepad++ activity [16] (**Confirmed**).

## Top recommendations

1. Inventory every Notepad++ install and move it to 8.9.2 or later; every version before 8.8.9 carries CVE-2025-15556, which is in KEV [10] [13] (**Inferred**).
2. In managed fleets, deploy the MSI with the auto-updater disabled and ship updates through your own software distribution [2] (**Confirmed** as vendor guidance).
3. Alert on unexpected child processes of the updater and hunt the published indicators over June to November 2025, as Rapid7 advises, with analysis from at least September 2025, as Kaspersky advises [14] [15] (**Reported**).

4. Treat every self-updating desktop tool as a supply-chain entry point and ask whether its updater verifies both the installer and the update metadata (**Inferred**).

## Scope and method

This brief covers CVE-2025-15556 and the 2025 update-channel abuse behind it, from the vendor's June 2025 start estimate to the CISA KEV catalog of 10 November 2026. It describes tradecraft at advisory level: no indicators, commands or payload detail. All dates are UTC.

| Grade | Meaning in this study |
|---|---|
| Confirmed | Stated in a primary opened for this study: the Notepad++ posts, the CVE and NVD records, VulnCheck's CNA advisory, the CISA KEV catalog and the ATT&CK site |
| Reported | Vendor research about other people's systems (Rapid7, Kaspersky), or a third party's account relayed by the Notepad++ author (the hosting provider, unnamed security experts) |
| Demonstrated | Shown in code (the patch commits) or by this study's check of the library's ATT&CK, CWE, CAPEC and D3FEND data files |
| Inferred | This study's own reasoning from cited facts, labelled where it appears |

Not checked: any CISA or joint advisory beyond the KEV entry, national CERT advisories, and the hosting provider's own statement, which is known only as quoted by the vendor.

## Part 1: what happened

| Date | Event | Sources | Grade |
|---|---|---|---|
| June 2025 | Incident begins, per the vendor's estimate | [1] | Reported |
| June to November 2025 | Window in which Rapid7 believes the activity ran | [14] | Reported |
| Late July to early August 2025 | Kaspersky chain 1: an update.exe launched by the updater leads through a Metasploit downloader to Cobalt Strike | [15] | Reported |
| 2 September 2025 | Hosting provider says attackers lost access to the shared server during scheduled kernel and firmware maintenance | [1] | Reported |
| Mid to late September 2025, again mid-October | Kaspersky chain 2: a Lua-based loader leads to Cobalt Strike | [15] | Reported |
| October 2025 | Kaspersky chain 3: DLL sideloading delivers Chrysalis; delivery servers rotated early, mid and late October; file names changed late October | [15] | Reported |
| 20 October 2025 | v8.8.7 published; the 8.8.9 note later says GlobalSign signing of binaries began with 8.8.7 | [4] [7] | Confirmed |
| 10 November 2025 | A security expert's analysis, cited by the vendor, says the attack ceased | [1] | Reported |
| 18 November 2025 | v8.8.8 says a potential WinGUp hijacking issue was addressed and advises a manual upgrade | [3] [7] | Confirmed |
| 30 November and 1 December 2025 | WinGUp and Notepad++ commits force certificate and signature checks on the downloaded installer | [8] [9] | Demonstrated |
| 1 December 2025 | Provider says the server hosted the update-URL script until this date | [1] | Reported |
| 2 December 2025 | Provider says attacker-held credentials stayed usable until remediation completed; the vendor's estimated end of the compromise | [1] | Reported |
| 9 December 2025 | v8.8.9 reports occasional redirection of WinGUp traffic and aborts updates that fail verification; the CVE's public disclosure date | [4] [10] | Confirmed |
| 26 January 2026 | v8.9.1, a regression-fix release whose note lists no security change; the vendor later recommends it as including the relevant security enhancement | [1] [5] [7] | Confirmed |
| 2 February 2026 | Vendor post "Notepad++ Hijacked by State-Sponsored Hackers"; VulnCheck advisory; Rapid7 report; CVE reserved | [1] [10] [12] [14] | Confirmed |
| 3 February 2026 | CVE published (00:50Z) and in NVD (01:15Z); Kaspersky report | [10] [11] [15] | Confirmed |
| 5 February 2026 | Vendor clarification: Notepad++ itself was not hacked | [2] | Confirmed |
| 12 February 2026 | CISA adds the CVE to KEV, due 5 March | [13] | Confirmed |

| Date | Event | Sources | Grade |
|---|---|---|---|
| 13 February 2026 | CISA-ADP SSVC: exploitation active, automatable no, technical impact total | [10] [11] | Confirmed |
| 16 February 2026 | v8.9.2 signs and verifies the update metadata | [6] [7] | Confirmed |

The dates disagree at the edges. The provider says server access ended on 2 September, the expert analysis says the attack ceased on 10 November, Kaspersky saw no payloads deployed from November 2025 onward, and the credentials stayed live until 2 December [1] [15] (**Reported**). The likely reading is that the attackers lost the server in September but kept credentials to internal services that could still steer update traffic, which the vendor's quotation of the provider supports [1] (**Inferred**).

## Part 2: the technical record

**The weakness.** The CVE says WinGUp in Notepad++ before 8.8.9 did not cryptographically verify update metadata or installers. An attacker who can intercept or redirect update traffic can therefore make it run a malicious installer with the user's privileges [10] (**Confirmed**). The CVSS v4.0 vector records network attack, high complexity and passive user interaction [11] (**Confirmed**). The high complexity is the point: the attacker needs control of the update path first [10] (**Inferred**).

**How the path was taken.** The vendor says the compromise happened at the infrastructure level of the former shared hosting provider [1] (**Confirmed** as vendor statement). The provider, as quoted, says no other client on that server was targeted and the attackers searched specifically for the notepad-plus-plus.org domain [1] (**Reported**). The vendor's response team spent a week on about 400 GB of server logs from the former provider and found signs of an intrusion but no concrete indicators such as hashes, domains or IP addresses; the former provider supplied indicators on 5 February [1] (**Reported**).

**What was delivered.** Rapid7 observed Notepad++ and its updater running before a malicious installer. That installer dropped a renamed Bitdefender Submission Wizard, which sideloads a DLL that decrypts shellcode and runs a custom backdoor Rapid7 named Chrysalis [14] (**Reported**). Rapid7 also found loaders that led to Cobalt Strike and Metasploit stages [14] (**Reported**). It found no artifact that settles whether the entry point was the updater or a replaced plugin [14] (**Reported**). Kaspersky describes three chains, all delivered as an update file launched by the updater: a Metasploit downloader to Cobalt Strike, a Lua-based loader to Cobalt Strike, and DLL sideloading to Chrysalis [15] (**Reported**).

**The fix, in three steps.** First, v8.8.8 addressed "a potential hijacking issue" [3] (**Confirmed**). Second, the 30 November and 1 December commits made the updater check the code-signing certificate and signature of the installer and abort on failure, shipped in v8.8.9 [4] [8] [9] (**Demonstrated**). Third, v8.9.2 signs the update-server XML with XMLDSig and verifies it, a "double lock" with the signed installer [6] (**Confirmed**). The same release removes the libcurl.dll dependency, which it names a DLL side-loading risk, drops two relaxed SSL options, and lets plugin management run only programs signed with the WinGUp certificate [6] (**Confirmed**).

## Part 3: who and why

The sources say three different things, and this study states each as given.

- **The vendor** says multiple independent security researchers assess the actor is likely a Chinese state-sponsored group [1]. It offers this to explain the selective targeting, not as a finding [1] (**Reported**). The clarification calls it a state-sponsored group, unnamed [2] (**Reported**).
- **Rapid7** attributes the activity to Lotus Blossom with moderate confidence [14] (**Reported**). Its basis is overlap with earlier Symantec research, including the renamed Bitdefender sideloading host, and shared Cobalt Strike infrastructure [14] (**Reported**). It gives the actor's targeting as Southeast Asia and, more recently, Central America, across government, telecom, aviation, critical infrastructure and media [14] (**Reported**).
- **Kaspersky** names no actor and gives no confidence level. It says only that the chain 3 technique is commonly used by Chinese-speaking actors [15] (**Reported**).
- **ATT&CK** describes Lotus Blossom (G0030) as a long-standing group targeting entities in Asia, with no China attribution and no Notepad++ or Chrysalis activity [16] [17] (**Confirmed**). The library's Threat Actors: China already records that gap [19] (**Confirmed**).

On motive, no source states one. A few hand-picked machines, including a government body, a financial firm and an IT service provider, fit espionage rather than crime (**Inferred**).

## Part 4: impact and response

**Victims.** Kaspersky counts about a dozen machines: individuals in Vietnam, El Salvador and Australia, a Philippine government organization, a financial organization in El Salvador, and a Vietnamese IT service provider [15] (**Reported**). The vendor gives no count and says most users were never affected [1] [2] (**Reported**). The IT service provider matters more than its single machine: a provider's compromise can reach its customers (**Inferred**).

**The vendor.** The vendor moved the website to a new hosting provider and signed the update XML [1] (**Confirmed**). It told users to install v8.9.1 manually [1] [2] (**Confirmed**). For enterprises, it recommends the v8.9.1 MSI deployed with the updater turned off, plus a check of the indicators published by the former host, Rapid7 and Kaspersky [2] (**Confirmed**). The provider says it rotated credentials, fixed vulnerabilities, checked its logs and found nothing similar after 2 December [1] (**Reported**).

**Government and CNA record.** VulnCheck, as CNA, published its advisory on 2 February, crediting Notepad++ internal discovery, with 8.8.9 as the fix [12] (**Confirmed**). CISA added the CVE to KEV on 12 February with a 5 March due date and the standard action: apply vendor mitigations, follow BOD 22-01 for cloud services, or stop using the product [13] (**Confirmed**). The KEV entry lists known ransomware use as Unknown [13] (**Confirmed**). The Intelligence Hub indexes the KEV row with a 12 February date [18] (**Confirmed**).

## Part 5: the defender and vulnerability-management view

**Version is not enough.** The CVE names 8.8.9 as fixed [10] (**Confirmed**). But 8.8.9 only checks the installer; the updater did not verify the update metadata until 8.9.2 [1] [6] (**Confirmed**). A scanner that passes 8.8.9 passes a host the vendor hardened again in 8.9.2. Target 8.9.2 or later (**Inferred**).

**Turn the updater off where you can.** Managed fleets can deploy the MSI with the updater disabled, removing the channel that was abused [2] (**Confirmed** as vendor guidance).

**Hunt the right window.** Rapid7 advises alerts for a suspicious child process of the updater and for Chrysalis, and an indicator hunt over June to November 2025 [14] (**Reported**). Kaspersky advises hunting installer temp directories, the temp.sh file-sharing service in DNS and web traffic, discovery commands under Notepad++ process trees, and Run keys pointing to temp folders. It also says to collect Windows events 4688 with command line, 5136 and 4663, and to retro-hunt to at least September 2025 [15] (**Reported**).

**Prioritization.** SSVC records active exploitation but "automatable: no" [10] (**Confirmed**). That fits a targeted campaign, not a worm. For most organizations the urgent work is inventory and upgrade. A full hunt matters most for government, telecom, financial and IT service organizations in the regions Rapid7 and Kaspersky name [14] [15] (**Inferred**).

### What is overstated and what is understated

- **Overstated:** "Notepad++ hacked." The vendor says the application code was not compromised [1] [2] (**Confirmed** as vendor statement). Also overstated is "Chinese state hackers" stated as fact: the vendor says "likely", Rapid7 says moderate confidence, Kaspersky names no one and ATT&CK draws no China link [1] [14] [15] [16] (**Reported** for the vendor, Rapid7 and Kaspersky; **Confirmed** for ATT&CK).
- **Understated:** the weakness predates its 2025 abuse: every version before 8.8.9 is affected [10] (**Confirmed**). Attacker credentials outlived the first fix, which shipped on 18 November while those credentials stayed usable until 2 December [1] [3] (**Reported**). Metadata signing became mandatory only on 16 February 2026, after the CVE record had named 8.8.9 as the fix [6] [10] (**Confirmed**).

## MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files, and every linked page exists in the library's `mitre/` tree [17] (**Demonstrated**). Rapid7 published ATT&CK ids for the Chrysalis chain [14]; this study bound each one to v20.0. Rapid7's T1574.002 DLL Side-Loading is revoked and maps to T1574.001 DLL [17] (**Demonstrated**). No industrial system is involved, so no ATT&CK for ICS techniques apply.

### Groups, software and campaigns

| Object | ATT&CK id | Relationship to this record |
|---|---|---|
| Lotus Blossom | G0030 | Rapid7's attribution, moderate confidence [14] (**Reported**); ATT&CK itself links no Notepad++ activity [16] |
| Cobalt Strike | S0154 | Second stage in Kaspersky chains 1 and 2 and in Rapid7's loaders [14] [15] (**Reported**) |
| SolarWinds Compromise | C0024 | Lineage only: an earlier trusted-update compromise [20] |
| 3CX Supply Chain Attack | C0057 | Lineage only: an earlier trusted-installer compromise [23] |

ATT&CK has no software object for Chrysalis or Metasploit and no campaign for this activity [17] (**Demonstrated**).

## ATT&CK Enterprise techniques

| ID | Name | Tactic(s) | Dated event or report | Sources |
|---|---|---|---|---|
| T1195.002 | Compromise Software Supply Chain | Initial Access | Selective redirection of update traffic, June to December 2025 (vendor, 2 Feb 2026); this study's mapping | [1] [10] |
| T1204.002 | Malicious File | Execution | Malicious update installer run after the updater (Rapid7, 2 Feb; Kaspersky, 3 Feb 2026) | [14] [15] |
| T1036 | Masquerading | Stealth | Renamed Bitdefender Submission Wizard (Rapid7) | [14] |
| T1574.001 | DLL | Stealth, Execution | DLL sideloading to Chrysalis (Rapid7; Kaspersky chain 3, October 2025) | [14] [15] |
| T1140 | Deobfuscate/Decode Files or Information | Stealth | Sideloaded DLL decrypts shellcode (Rapid7) | [14] |
| T1027 | Obfuscated Files or Information | Stealth | Listed by Rapid7 | [14] |
| T1027.007 | Dynamic API Resolution | Stealth | Listed by Rapid7 | [14] |
| T1106 | Native API | Execution | Listed by Rapid7 | [14] |
| T1055 | Process Injection | Stealth, Privilege Escalation | Listed by Rapid7 | [14] |
| T1620 | Reflective Code Loading | Stealth | Listed by Rapid7 | [14] |
| T1059.003 | Windows Command Shell | Execution | Listed by Rapid7 | [14] |
| T1083 | File and Directory Discovery | Discovery | Listed by Rapid7 | [14] |
| T1005 | Data from Local System | Collection | Listed by Rapid7 | [14] |
| T1105 | Ingress Tool Transfer | Command and Control | Downloaders to Cobalt Strike (Rapid7; Kaspersky chains 1 and 2, July to October 2025) | [14] [15] |
| T1041 | Exfiltration Over C2 Channel | Exfiltration | Listed by Rapid7 | [14] |
| T1071.001 | Web Protocols | Command and Control | Listed by Rapid7 | [14] |
| T1573 | Encrypted Channel | Command and Control | Listed by Rapid7 | [14] |
| T1547.001 | Registry Run Keys / Startup Folder | Persistence, Privilege Escalation | Listed by Rapid7; Kaspersky's Run-key hunt advice (11 Feb 2026) | [14] [15] |
| T1543.003 | Windows Service | Persistence, Privilege Escalation | Listed by Rapid7 | [14] |
| T1480.002 | Mutual Exclusion | Stealth | Listed by Rapid7 | [14] |
| T1070.004 | File Deletion | Stealth | Listed by Rapid7 | [14] |

Fit notes (**Inferred**): T1195.002 is this study's mapping; Rapid7 does not list it, but the record describes delivery through a hijacked software-update channel. The Rapid7 ids are bound as Rapid7 lists them. Rapid7 dates its report 2 February 2026, updated 9 February, and gives a June to November 2025 window. T1557 Adversary-in-the-Middle was considered and not bound: the record describes redirection by a compromised provider, not interception on the network path.

## CWE and CAPEC

| CWE | Name | Where it is assigned | Sources |
|---|---|---|---|
| CWE-494 | Download of Code Without Integrity Check | CVE record, NVD, VulnCheck advisory and KEV entry | [10] [11] [12] [13] |

| CAPEC | Name | Via | Where it meets the record |
|---|---|---|---|
| CAPEC-187 | Malicious Automated Software Update via Redirection | CWE-494 in the library's CAPEC data | Update traffic redirected to serve compromised updates [1] |
| CAPEC-186 | Malicious Software Update | CWE-494; the library maps it to T1195.002 | The malicious update installer [1] [14] |

The CVE record names no CAPEC id; both are this study's mapping through CWE-494 [17] (**Demonstrated** link, **Inferred** fit). The parents CAPEC-184 and CAPEC-185 also relate to CWE-494 and are not bound separately. See the CWE Reference and CAPEC Reference.

## D3FEND countermeasures

| D3FEND countermeasure | Techniques the library maps it to | Where it meets the record |
|---|---|---|
| Software Update and Restore Software | T1195.002 | Manual reinstall of a signed release, 8.9.2 or later [2] [6] |
| Software Inventory and Asset Vulnerability Enumeration | T1195.002 | Finding installs before 8.8.9 [10] [13] |
| Executable Allowlisting | T1204.002, T1547.001 | v8.9.2 lets plugin management run only WinGUp-signed programs [6] (**Inferred** fit) |
| File Analysis and File Integrity Monitoring | T1204.002, T1574.001 | Finding the dropped sideloading pair [14] (**Inferred**) |
| System Init Config Analysis | T1547.001 | Kaspersky's Run-key hunt [15] |
| Outbound Traffic Filtering and Certificate Analysis | T1071.001 (both); T1105 (Outbound Traffic Filtering only) | Command-and-control and the file-sharing service in Kaspersky's hunt advice [15] (**Inferred**) |

Process Lineage Analysis matches Rapid7's updater child-process alert [14], though the library does not map it to these techniques (**Inferred**). See the D3FEND Reference.

### Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/notepad-plus-plus-update-hijack-2026.json` (open in Navigator), listed on the Navigator layers page. It is pinned to ATT&CK v20, domain `enterprise-attack`. A score of 75 means the vendor, CVE or KEV record describes the behavior; 50 means vendor research describes it. Each comment names the event and the source numbers.

## Cross-cutting themes

- **The update channel is the product's most trusted code path.** The same pattern runs through SolarWinds, the CCleaner and ASUS Live Update compromises in APT41: The Public Record, NotPetya's M.E.Doc updater in Sandworm, and 3CX in The Year 2023 in Intrusions [20] [21] [22] [23] (**Confirmed** in those studies).
- **Hosting is part of the supply chain.** Here the vendor places the compromise at the hosting provider, not in Notepad++ code; a shared host was enough [1] [2] (**Inferred**). Compare the build-side compromise in The XZ Utils Backdoor.
- **Sign the instructions as well as the package.** Signed installers left the metadata that told the updater what to fetch unverified by the client until 8.9.2 [1] [6] (**Inferred**).
- **Small, selective and long.** A dozen machines over six months [1] [15] is a pattern that mass-exploitation telemetry misses (**Inferred**).

## Sources

All sources were opened on 11 November 2026, except [10] and [13], which were re-opened on 13 November 2026.

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 1 | Notepad++, "Notepad++ Hijacked by State-Sponsored Hackers", 2 Feb 2026, edited to 5 Feb | notepad-plus-plus.org/news/hijacked-incident-info-update/ | 2026-11-11 | Confirmed (vendor statement); relayed provider and expert claims Reported |
| 2 | Notepad++, clarification on the security incident, 5 Feb 2026 | notepad-plus-plus.org/news/clarification-security-incident/ | 2026-11-11 | Confirmed |
| 3 | Notepad++, v8.8.8 release, 18 Nov 2025 | notepad-plus-plus.org/news/v888-released/ | 2026-11-11 | Confirmed |
| 4 | Notepad++, v8.8.9 release, 9 Dec 2025 | notepad-plus-plus.org/news/v889-released/ | 2026-11-11 | Confirmed |
| 5 | Notepad++, v8.9.1 release, 26 Jan 2026 | notepad-plus-plus.org/news/v891-released/ | 2026-11-11 | Confirmed |
| 6 | Notepad++, v8.9.2 release, 16 Feb 2026 | notepad-plus-plus.org/news/v892-released/ | 2026-11-11 | Confirmed |
| 7 | Notepad++ GitHub releases (publish times) | github.com/notepad-plus-plus/notepad-plus-plus/releases | 2026-11-11 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 8 | Notepad++ commit bcf2aa68, 1 Dec 2025 | github.com/notepad-plus-plus/notepad-plus-plus/commit/bcf2aa68... | 2026-11-11 | Demonstrated |
| 9 | WinGUp commit ce003754, 30 Nov 2025 | github.com/notepad-plus-plus/wingup/commit/ce003754... | 2026-11-11 | Demonstrated |
| 10 | CVE Program record CVE-2025-15556 (CNA VulnCheck, with CISA-ADP) | cveawg.mitre.org/api/cve/CVE-2025-15556 | 2026-11-13 | Confirmed |
| 11 | NVD, CVE-2025-15556 | nvd.nist.gov/vuln/detail/CVE-2025-15556 | 2026-11-11 | Confirmed |
| 12 | VulnCheck advisory, WinGUp updater lacks update integrity verification, 2 Feb 2026 | vulncheck.com/advisories/notepad-plus-plus-wingup-... | 2026-11-11 | Confirmed |
| 13 | CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10 | cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json | 2026-11-13 | Confirmed |
| 14 | Rapid7, Chrysalis backdoor and Lotus Blossom's toolkit, 2 Feb 2026, updated 9 Feb | rapid7.com/blog/post/tr-chrysalis-backdoor-... | 2026-11-11 | Reported |
| 15 | Kaspersky Securelist, Notepad++ supply chain attack, 3 Feb 2026, updated 11 Feb | securelist.com/notepad-supply-chain-attack/118708/ | 2026-11-11 | Reported |
| 16 | MITRE ATT&CK, Lotus Blossom G0030 (version 4.0, modified 31 Jul 2026) | attack.mitre.org/groups/G0030/ | 2026-11-11 | Confirmed |
| 17 | TeamStarWolf library data: `data/attack/` (ATT&CK v20.0, including `superseded_by.jsonl` and `technique_to_d3fend.jsonl`), `data/weaknesses/` and the `mitre/` page tree | github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack | 2026-11-11 | Demonstrated |
| 18 | Team Star Wolf Intelligence Hub feed, row kev-CVE-2025-15556 | teamstarwolf.github.io/intelligence-hub/data/feed.json | 2026-11-11 | Confirmed (index only) |
| 19 | TeamStarWolf, China-Attributed Threat Actors | /case-studies/THREAT_ACTORS_CHINA.md | 2026-11-11 | Confirmed |
| 20 | TeamStarWolf, SolarWinds and SUNBURST | /case-studies/SOLARWINDS_SUNBURST.md | 2026-11-11 | Confirmed |
| 21 | TeamStarWolf, APT41: The Public Record | /case-studies/APT41_PUBLIC_RECORD.md | 2026-11-11 | Confirmed |
| 22 | TeamStarWolf, Sandworm: The Operations in the Public Record | /case-studies/SANDWORM_OPERATIONS.md | 2026-11-11 | Confirmed |
| 23 | TeamStarWolf, The Year 2023 in Intrusions: A Dated Record | /case-studies/CHRONICLE_2023.md | 2026-11-11 | Confirmed |

Not opened, so not cited as sources: the hosting provider's own statement, any CISA or joint advisory beyond KEV, national CERT advisories and the Symantec research Rapid7 cites.

*© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.*

*© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/*

*© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/*

*© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/*

*The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.*

## Related references

- SolarWinds and SUNBURST, APT41: The Public Record, Sandworm, npm Supply-Chain Attacks, The XZ Utils Backdoor, Threat Actors: China
- The Year 2026 in Intrusions, The TeamPCP Supply-Chain Campaign of 2026
- Supply Chain Security Reference, Vulnerability Management Reference, Threat Hunting Reference, Endpoint Security Reference
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Group: G0030 Lotus Blossom; software: S0154 Cobalt Strike; campaigns (lineage only): C0024 SolarWinds Compromise, C0057 3CX Supply Chain Attack
- Techniques: T1195.002, T1204.002, T1574.001, T1036, T1140, T1105, T1547.001, T1543.003, T1071.001
- CAPEC: CAPEC-187, CAPEC-186
- Navigator layers, including this study's layer, notepad-plus-plus-update-hijack-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies